

# Bastionado de redes y sistemas

Tema 1 · Riesgos, análisis y Economía Circular

Máster CIBER · Madrid · Sesión 1

# ¿Qué es bastionar?

**Reducir la superficie de ataque** de un sistema o una red **antes** de que alguien la aproveche.

Es el hilo conductor de todo el módulo: planificar, proteger el acceso, diseñar redes seguras y endurecer cada sistema.

## Lo que más se encuentra en una auditoría

1

### Servicios que nadie usa

Siguen instalados y escuchando en la red.

2

### Credenciales por defecto

admin/admin en routers, cámaras y sensores.

3

### Redes planas

Cualquier equipo puede hablar con cualquier otro.

# El recorrido del módulo

Siete resultados de aprendizaje, en el orden en que se protege un sistema real

**Analizar riesgos y planificar**



Hoy empezamos por el RA1: no se puede proteger lo que no se ha analizado.

# Cómo se evalúa

Cada RA **se aprueba por separado.**

No se compensan entre sí: un 9 en un RA no salva un 4 en otro. Todo el material y las entregas están en el campus.

## Nota por RA

Sobre 10. Necesitas al menos un 5 en cada uno de los siete.

## Actividades obligatorias

Se entregan en PDF por el campus, dentro de plazo.

## Autoevaluaciones

15 preguntas por tema y 3 intentos. Úsalas para repasar.

## Examen final

Entra todo el temario, también los temas sin actividad obligatoria.

# Objetivos de hoy

Al terminar la sesión serás capaz de:

Criterios de evaluación a), b), c) y d) del RA1.

01

**Identificar** los riesgos de un entorno Industria 4.0: activos, amenazas y vulnerabilidades.

02

**Analizar** esos riesgos con un método: probabilidad × impacto, teniendo en cuenta los controles que ya existen.

03

**Priorizar** las medidas de seguridad con criterios de Economía Circular.

# Industria 4.0

01



# IT frente a OT

La Industria 4.0 conecta dos mundos con prioridades distintas

## IT · Oficina

## OT · Planta

### Qué protege

Datos e información

Procesos físicos y personas

### Prioridad

Confidencialidad

Disponibilidad y seguridad física

### Vida útil

3–5 años

15–20 años

### Parches

Frecuentes, a menudo automáticos

Solo en paradas planificadas

### Si falla

Fuga o pérdida de datos

Paradas, daños físicos, riesgo humano

# Cuatro riesgos clave

**¿Cuál es el más difícil de resolver?**

Debatirlo entre todos: no vale una respuesta rápida, hay que justificarla.

## Dispositivos IoT

Muchos se diseñaron sin pensar en la seguridad: credenciales de fábrica y firmware sin actualizar.

## Infraestructura crítica

Energía, agua, transporte o alimentación: un ataque tiene impacto en toda la sociedad.

## Interconexión IT/OT

Lo que antes estaba aislado ahora comparte red con el correo y el ERP.

## Falta de estandarización

Muchos fabricantes y protocolos, a menudo sin autenticación ni cifrado.

## Dos casos reales

# 2010

### Stuxnet

Malware que manipuló los PLC de las centrifugadoras de Natanz (Irán) y las dañó físicamente mientras las pantallas mostraban valores normales.

**Lección:** Aislar la red no basta.

# 2021

### Colonial Pipeline

Ransomware que entró por una cuenta VPN antigua, sin MFA y con una contraseña filtrada. La empresa paró el oleoducto varios días por precaución.

**Lección:** Una credencial olvidada también es superficie de ataque.

# 02 Análisis de riesgos



# Cinco conceptos

El análisis de riesgos es un proceso: se repite cada vez que algo cambia

1

## Activo

Lo que tiene valor para la organización

2

## Amenaza

Lo que puede causar daño

3

## Vulnerabilidad

La debilidad que permite el daño

4

## Control existente

Lo que ya está protegiendo

5

## Riesgo

Probabilidad × impacto

**Ejemplo:** sensor de temperatura (activo) · acceso no autorizado (amenaza) · contraseña de fábrica (vulnerabilidad) · ninguno (control) ·  $P2 \times I2 = 4$ , riesgo medio

# La matriz de riesgos

$$R = P \times I$$

Puntúa la probabilidad y el impacto de 1 a 3 y justifica siempre por qué.

|     |         |
|-----|---------|
| 1-2 | Bajo    |
| 3-4 | Medio   |
| 6   | Alto    |
| 9   | Crítico |

Probabilidad

|   |                        |                        |                          |
|---|------------------------|------------------------|--------------------------|
| 3 | <div>3<br/>Medio</div> | <div>6<br/>Alto</div>  | <div>9<br/>Crítico</div> |
| 2 | <div>2<br/>Bajo</div>  | <div>4<br/>Medio</div> | <div>6<br/>Alto</div>    |
| 1 | <div>1<br/>Bajo</div>  | <div>2<br/>Bajo</div>  | <div>3<br/>Medio</div>   |
|   | 1                      | 2                      | 3                        |
|   | Impacto                |                        |                          |

# ¿Qué hacemos con cada riesgo?

## Mitigar

Aplicar controles que bajen la probabilidad o el impacto.

## Transferir

Pasárselo a un tercero: un seguro o un proveedor.

## Evitar

Dejar de hacer la actividad que lo genera.

## Aceptar

Asumirlo de forma consciente, documentada y firmada.

## Metodologías y estándares de referencia

### MAGERIT v3

Metodología pública española del CCN, usada en la Administración y en el ENS.

### ISO/IEC 27005

Norma internacional de gestión de riesgos de seguridad de la información.

### IEC 62443

Familia de estándares de ciberseguridad para sistemas industriales.

# 03 Economía Circular



# Las 3R aplicadas a la seguridad

Lo que no existe no se puede atacar

**R**

## Reducir

Menos software, servicios y equipos significa menos superficie de ataque.

**Ejemplo:** Desinstalar los servicios que nadie usa en un servidor de planta.

**R**

## Reutilizar

Alargar la vida útil de los equipos sin comprometer la seguridad.

**Ejemplo:** Actualizar el firmware de un sensor en lugar de sustituirlo.

**R**

## Reciclar

Recuperar datos y recursos de los sistemas que se retiran.

**Ejemplo:** Migrar los datos de un equipo obsoleto y borrarlo de forma segura antes de retirarlo.

Vuestro criterio de evaluación lo pide: priorizar medidas teniendo en cuenta la Economía Circular.

# Caso práctico: Envasados Meseta

Sois el nuevo equipo de ciberseguridad de una planta de zumos. La dirección quiere un análisis de riesgos y un plan de medidas priorizado.

**Grupos de 3 o 4 · 45 minutos**

Toda la información está en la ficha de trabajo.

**01**

## **Matriz de riesgos**

Al menos cinco riesgos, con activo, amenaza, vulnerabilidad, control existente, P, I y nivel.

**02**

## **Priorizar**

Ordenadlos y proponed una medida para cada uno de los tres más altos.

**03**

## **Economía Circular**

Marcad qué medidas aplican reducir, reutilizar o reciclar, y explicad cuál.

# Test rápido

1

Una contraseña de fábrica en un sensor, ¿es una amenaza o una vulnerabilidad?

2

En un entorno OT, ¿qué suele ir primero: la confidencialidad o la disponibilidad?

3

Probabilidad 2 e impacto 3. ¿Qué nivel de riesgo es?

# Antes del próximo martes

01

## Actividad obligatoria

Tema 1, en el campus. Se entrega en PDF antes de la fecha indicada. Parte del caso de hoy, pero redáctalo con tus palabras.

02

## Prepara el laboratorio

Instala VirtualBox o VMware Workstation y descarga las ISO de Ubuntu Server y Kali Linux. Con Mac de chip Apple, versiones ARM.

03

## Próxima sesión

Tema 2: del análisis al plan de medidas técnicas. Guías de buenas prácticas y estándares de securización.

# ¡Gracias!

¿Dudas?